

****04.03.2025****

****Sanction for Violation of GDPR****

The National Authority for the Supervision of Personal Data Processing completed, in January 2025, an investigation into the operator WEBRASOFT SRL and found a violation of the provisions of Article 32 paragraph (1) letters b) and d) and Article 32 paragraph (2) of Regulation (EU) 2016/679.

As such, the operator was sanctioned with a fine amounting to 99,518.00 lei (equivalent to 20,000 euros).

The investigation was initiated following a notification of a personal data security breach, in accordance with the provisions of Article 33 of Regulation (EU) 2016/679.

During the investigation, it was found that the operator, which owned an online invoicing site, was the victim of a cyber attack, through which the server storing the customer database was illegally accessed.

Additionally, during the investigation, it was revealed that the attacker unauthorizedly accessed the personal data held by the operator, which affected the confidentiality of personal data of a large number of clients (name, surname, personal identification number, home address, phone number, email address, bank account number).

As a result, it was found that WEBRASOFT SRL did not conduct periodic testing, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing, intended to effectively implement the principles of data protection and to integrate the necessary safeguards within the processing, in order to meet the requirements of Regulation (EU) 2016/679 and to protect the rights of data subjects, including the ability to ensure the confidentiality, integrity, availability, and continuous resilience of processing systems and services.

This situation led to unauthorized access by a third party to the personal data held by the operator, thus violating the provisions of Article 32 paragraph (1) letters b) and d) and Article 32 paragraph (2) of the GDPR.

Under Article 58 paragraph (2) letter d) of Regulation (EU) 2016/679, the implementation of technical and organizational measures for a logging system of all valid accesses/errors regarding unsuccessful access attempts on the servers within the operator's IT infrastructure was ordered, with retention of these logs for at least 30 days, including the creation of backups of the logging files (logs).

It is noted that the operator has paid the imposed fine.

****Legal and Communication Department****

****N.A.S.P.D.C.P****